

IR-2026-0108

Post-Employment Data Exfiltration

Incident Ref: IR-2026-0108

Classification: Critical Breach of Confidentiality

Impacted CIA Component: Confidentiality

1. Executive Summary

A forensic analysis identifies a massive data exfiltration event involving 20,000+ institutional files. The breach was executed by a former employee after their official termination date of December 25, 2025. This incident demonstrates a total failure of the offboarding process.

2. Forensic Observations

- **Persistence:** The subject's credentials remained active post-employment, permitting sustained access via multiple IP addresses (I1 through I8).
- **Peak Exfiltration (2026-01-06):** A high-volume download session occurred involving institutional pacing guides, teacher resources, and highly sensitive **CVs and personal records (PII)** of other staff.
- **Targeted Information:** The actor targeted "O8 Management Schedules" and "O9 Official Group" documents, which contain strategic institutional intellectual property and exam keys.
- **Pattern:** Activity frequently occurred after-hours (20:00 ICT), indicating a deliberate attempt to evade casual observation.

3. Root Cause Analysis (RCA)

- **Primary Failure: Annex A 6.4 (Termination or change of employment responsibilities).** The ISMS failed to trigger a mandatory account revocation upon the "Last Working Day."
- **Procedural Gap: Clause 7.2 (Competence).** No formal offboarding checklist was shared between HR and IT, resulting in "Shadow Accounts" remaining active.
- **Technical Gap: Annex A 8.12 (Data leakage prevention).** The system lacked egress monitoring to identify and block high-volume downloads from a single user account.

4. Statement of Breach and Corrective Actions

- **Scope:** 20,000+ files, including third-party licensed materials and sensitive PII.
- **Containment:** Immediate account revocation and credential rotation for all impacted Shared Drives.
- **Corrective Action Plan:**
 1. Establish a **Joint HR-IT Offboarding Policy** (Clause 5.2).

2. Automate account suspension via HRIS integration.
3. Implement **Annex A 8.16 (Monitoring activities)** to flag "Anomaly-based" downloads (e.g., >100 files/hour).